

VaultScan — Misconfiguration Detection List

Complete catalogue of misconfigurations the current scan engine detects in AWS. Source of truth: [backend/scanner_engine.py](#). Demo mode runs the same rules against simulated resources.

Total checks: 29 CRITICAL 8 · HIGH 14 · MEDIUM 6 · LOW 1

By service: S3 (7) · IAM (6) · EC2 / SG (9) · EC2 (3) · RDS (4)

#	Service	Rule ID	Severity	Finding title	Detection condition
1	S3	S3-PUBLIC-ACL	CRITICAL	S3 Bucket is Publicly Accessible via ACL	Bucket ACL grants AllUsers or AuthenticatedUsers (public ACL).
2	S3	S3-PUBLIC-POLICY	CRITICAL	S3 Bucket Policy Allows Public Principal	Bucket policy allows Principal "*" (public).
3	S3	S3-BPA-INCOMPLETE	HIGH	S3 Public Access Block Incomplete	Not all four Block Public Access flags are enabled.
4	S3	S3-BPA-MISSING	HIGH	S3 Public Access Block Not Configured	No Public Access Block configuration on the bucket.
5	S3	S3-NO-ENCRYPTION	HIGH	S3 Bucket Encryption Not Enabled	No default server-side encryption (SSE-S3/KMS).
6	S3	S3-NO-VERSIONING	MEDIUM	S3 Bucket Versioning Not Enabled	Versioning is not Enabled.
7	S3	S3-ACCESS-DENIED	MEDIUM	Unable to list S3 buckets	Scanner role cannot call ListBuckets (permission gap).
8	IAM	IAM-ADMIN-POLICY	HIGH	IAM User Has AdministratorAccess	Managed AdministratorAccess policy attached to user.
9	IAM	IAM-INLINE-STAR	HIGH	IAM User Overly Permissive Inline Policy	Inline policy allows Action:* on Resource:.*
10	IAM	IAM-NO-MFA	HIGH	IAM User Has No MFA	User has zero MFA devices configured.
11	IAM	IAM-ROLE-ADMIN	HIGH	IAM Role Has AdministratorAccess	Role has AdministratorAccess managed policy.
12	IAM	IAM-OLD-KEY	MEDIUM	IAM Access Key Older Than 90 Days	Active access key age > 90 days.
13	IAM	IAM-ACCESS-DENIED	MEDIUM	Unable to list IAM users	Scanner role cannot call ListUsers.
14	EC2 / SG	SG-OPEN-ALL	CRITICAL	Security Group Allows All Traffic from Internet	Ingress IpProtocol=-1 (or all ports) from 0.0.0.0/0 or ::/0.
15	EC2 / SG	SG-OPEN-22	CRITICAL	Security Group Exposes SSH (22) to the World	TCP 22 from 0.0.0.0/0 or ::/0.
16	EC2 / SG	SG-OPEN-3389	CRITICAL	Security Group Exposes RDP (3389) to the World	TCP 3389 from 0.0.0.0/0 or ::/0.
17	EC2 / SG	SG-OPEN-3306	CRITICAL	Security Group Exposes MySQL (3306) to the World	TCP 3306 from 0.0.0.0/0 or ::/0.
18	EC2 / SG	SG-OPEN-5432	CRITICAL	Security Group Exposes PostgreSQL (5432) to the World	TCP 5432 from 0.0.0.0/0 or ::/0.
19	EC2 / SG	SG-OPEN-1433	HIGH	Security Group Exposes MSSQL (1433) to the World	TCP 1433 from 0.0.0.0/0 or ::/0.
20	EC2 / SG	SG-OPEN-27017	HIGH	Security Group Exposes MongoDB (27017) to the World	TCP 27017 from 0.0.0.0/0 or ::/0.
21	EC2 / SG	SG-OPEN-6379	HIGH	Security Group Exposes Redis (6379) to the World	TCP 6379 from 0.0.0.0/0 or ::/0.
22	EC2 / SG	SG-OPEN-9200	HIGH	Security Group Exposes Elasticsearch (9200) to the World	TCP 9200 from 0.0.0.0/0 or ::/0.
23	EC2	EBS-NO-ENCRYPTION	HIGH	EBS Volume Not Encrypted	EBS volume Encrypted=false.
24	EC2	EC2-IMDSV1	HIGH	EC2 Instance Allows IMDSv1	Public IP instance does not require IMDSv2 (HttpTokens != required).

#	Service	Rule ID	Severity	Finding title	Detection condition
25	EC2	EC2-ACCESS-DENIED	MEDIUM	Unable to describe security groups	Scanner role cannot call DescribeSecurityGroups.
26	RDS	RDS-PUBLIC	CRITICAL	RDS Instance Publicly Accessible	DB instance PubliclyAccessible=true.
27	RDS	RDS-NO-ENCRYPTION	HIGH	RDS Storage Not Encrypted	StorageEncrypted=false.
28	RDS	RDS-NO-BACKUP	MEDIUM	RDS Automated Backups Disabled	BackupRetentionPeriod is 0 / disabled.
29	RDS	RDS-SKIP	LOW	RDS scan skipped	Non-access-denied error while describing DB instances.

Severity legend

CRITICAL — Internet exposure or direct path to data/admin compromise. Fix immediately.

HIGH — Serious weakness (encryption, MFA, admin policies, IMDSv1). Fix this week.

MEDIUM — Hardening / resilience / scanner access gaps. Plan remediation.

LOW — Informational skip/edge cases.

Notes

- SG-OPEN-* rules fire only when the port range includes the listed port and CIDR is 0.0.0.0/0 or ::/0.
- Access-denied rules mean the scan role lacks permission — they are not “clean environment” signals.
- Demo / Simulate mode creates intentionally weak resources and runs the same rule functions.